

PART 4

API & Authentication

FinVault – MERN Stack Virtual Stock Trading Platform

DOCUMENT INFORMATION

Project Title	FinVault – Virtual Stock Trading Platform
Document Phase	Phase 1: Project Documentation
Part	Part 4 – API & Authentication
Author	Ganesh Basode
Affiliation	Department of Computer Science & Engineering
Institution	G. Pullaiah College of Engineering and Technology (GPCET)
Date	July 2026
Status	Final Version

1. Authentication & Security Flow

FinVault utilizes modern JSON Web Tokens (JWT) and bcrypt hashing protocols to implement stateless session authorization across all protected resources.

1.1 Security Implementation Details

- **Password Security:** When a user registers, their plain-text password is encrypted via bcrypt using a salt factor of 10. The resulting hash is stored in the database.
- **Token Generation:** When logging in, the server evaluates password hashes. On a match, it issues a signed JWT token containing the user's primary database ID.
- **Client Storage:** The frontend stores this JWT token in **LocalStorage**.
- **Request Attachment:** An Axios interceptor automatically injects the token in the **Authorization** header as **Bearer [token]** for all api requests.
- **Server Middleware:** The **authMiddleware.js** interceptor reads the authorization header, verifies the signature, and binds the payload to the request object (req.user).

1.2 Role-Based Access Control (RBAC)

Certain routes (like adding stocks or viewing all transaction histories) require administrative rights. The system checks the **isAdmin** field of the user's profile database object. If set to false, the request is terminated with a **403 Forbidden** status.

2. REST API Documentation

Below is a reference of the REST APIs exposed by the Express application server.

2.1 Core Authentication Endpoints

Method	Endpoint	Access	Description
POST	/api/auth/register	Public	Register user
POST	/api/auth/login	Public	Login user, returns JWT token

2.2 Stock Catalog Endpoints

Method	Endpoint	Access	Description
GET	/api/stocks	Public	Fetch all listed stocks
GET	/api/stocks/:symbol	Public	Get details & price history of a stock

2.3 Portfolio & Trading Endpoints

Method	Endpoint	Access	Description
POST	/api/trade/buy	Protected	Execute a stock purchase
POST	/api/trade/sell	Protected	Execute a stock sale
GET	/api/portfolio	Protected	Retrieve user portfolio holdings
GET	/api/transactions	Protected	Fetch transaction ledger logs

2.4 Watchlist Endpoints

Method	Endpoint	Access	Description
GET	/api/watchlist	Protected	Fetch user watchlist stock items
POST	/api/watchlist	Protected	Pin a stock symbol to watchlist
DELETE	/api/watchlist/:id	Protected	Unpin stock from watchlist

2.5 Admin Control Endpoints

Method	Endpoint	Access	Description
GET	/api/admin/users	Admin Only	Retrieve list of all users
POST	/api/admin/stocks	Admin Only	Create new stock item
PUT	/api/admin/stocks/:id	Admin Only	Modify stock attributes
DELETE	/api/admin/stocks/:id	Admin Only	Delete stock catalog listing

3. Sample Payloads

3.1 User Registration Payload (POST)

```
// Request Body
{
  "name": "Jane Doe",
  "email": "jane@example.com",
  "password": "mysecretpassword123"
}
```

3.2 Trade Execution Payload (POST)

```
// Request Body
{
  "stockId": "65f8c32b90b8f1c84b12d1e0",
  "quantity": 15
}
```